للمتدرب بعد الحل

الإجابات النموذجية وطريقة الحل

كيف تبدأ في GRC · لكل تمرين: الطريقة، والإجابة، والسبب، والأخطاء الشائعة

بيانات تدريبية افتراضية — رُفاد للخدمات اللوجستية (شركة افتراضية لأغراض التدريب)

كيف تستخدم هذا الملف

- افتحه بعد أن تكتب إجابتك في الكراسة، لا قبلها. قيمة التمرين في المحاولة.
- ابدأ بقسم «طريقة الحل»: هو ما ستكرره في العمل الحقيقي، والإجابة نتيجته.
- الإجابة النموذجية ليست الصياغة الوحيدة الصحيحة. قسم «متى تكون إجابتك مقبولة» يبين ما يمكن أن يختلف، وما لا يمكن.
- إن اختلفت درجتك أو قرارك فاسأل: هل لدي مبرر مكتوب من البيانات؟ المبرر أهم من الرقم.
- التمارين بترتيب العرض، وأرقام الشرائح تشير إلى شرائح الإجابة فيه.

تنبيه: رُفاد شركة افتراضية لأغراض التدريب. اسمها وأشخاصها وأنظمتها وبياناتها وأدلتها مختلقة، وأي تشابه مع جهة حقيقية غير مقصود. رُفاد شركة خاصة ليست جهة حكومية ولا تابعة لجهة حكومية، ولا تملك بنية تحتية وطنية حساسة، فالضوابط الأساسية ECC-2:2024 غير ملزمة لها. في هذه الحالة التدريبية تبنّتها رُفاد طوعاً مرجعاً داخلياً.

التمرين 1: صنّف مهام رُفاد: حوكمة أم مخاطر أم امتثال؟

الإجابة في العرض: الشريحة 16.

طريقة الحل

1. اقرأ المهمة واسأل سؤالاً واحداً: ما الذي تجيب عنه؟
2. إن كانت تضع قاعدة، أو تقرر، أو تشكل هيكلاً للإشراف والمساءلة: فهي حوكمة G.
3. إن كانت تقدر ما قد يحدث وحجمه، أو تختار كيف نعالجه: فهي مخاطر R.
4. إن كانت تثبت بالأدلة أن الجهة تطبق متطلباً مكتوباً: فهي امتثال C.

الإجابة النموذجية

#	المهمة	الحرف	السبب
1	الرئيس التنفيذي يعتمد سياسة الأمن السيبراني	G	قرار ممن يملك الصلاحية يضع القواعد.
2	تقدير احتمال وأثر سرقة حاسوب عليه ملفات الرواتب	R	تحليل ما قد يحدث وحجمه لترتيب الأولوية.
3	جمع أدلة مراجعة الصلاحيات لتقييم الالتزام بـ ECC	C	إثبات تطبيق متطلب محدد بالأدلة.
4	تشكيل لجنة الأمن السيبراني وتحديد مهامها	G	هيكل إشراف ومسؤوليات ومتابعة.
5	اختيار خطة معالجة لخطر حساب المورد المشترك	R	قرار معالجة لخطر قُيّم مستواه.
6	مطابقة عقد المورد مع بنود ECC 4-1-2	C	مقارنة الوضع القائم بمتطلب مكتوب.

ملاحظة: المهام متداخلة في الواقع: اعتماد خطة معالجة للخطر قرار حوكمة أيضاً. المهم أن تعرف السؤال الأساسي الذي تجيب عنه كل مهمة.

متى تكون إجابتك مقبولة وإن اختلفت عن النموذج

- المهمة 5: إن كتبت G لأن اعتماد خطة المعالجة قرار من صاحب الصلاحية، وبيّنت ذلك، فإجابتك مقبولة. السؤال الأساسي فيها عن معالجة الخطر، لذلك النموذج R.

أخطاء شائعة

- التصنيف بكلمة مفتاحية: كل ما فيه «ECC» امتثال، وكل ما فيه «لجنة» حوكمة. المهمة 6 امتثال لأنها مقارنة بمتطلب، لا لأن فيها ECC.
- خلط تقييم الخطر بتقييم الالتزام: «تقدير احتمال وأثر» مخاطر، و«جمع أدلة» امتثال.

اختبار الوحدة 01: ما هو GRC؟

1. أي مهمة امتثال في رُفاد؟
الإجابة: (ج) جمع أدلة مراجعة الصلاحيات لتقييم الالتزام بمتطلب
- لماذا: الامتثال يثبت بالأدلة تطبيق متطلب مكتوب.
- لماذا ليس (أ): قرار ممن يملك الصلاحية: حوكمة.
- لماذا ليس (ب): تقدير ما قد يحدث وحجمه: مخاطر.

2. «فرز التنبيهات والتحقيق فيها» من عمل:
الإجابة: (ب) مركز عمليات الأمن
- لماذا: مركز العمليات يراقب ويستجيب لما يحدث الآن.
- لماذا ليس (أ): GRC يسأل: هل نحمي ما يهم، وهل نلتزم ونثبت؟ ولا يفرز التنبيهات.

3. أي عبارة صحيحة؟

الإجابة: (ب) السياسة بداية العمل، والجزء الأكبر التحقق من تطبيقها بالأدلة

• لماذا: هذا ما يفعله محلل GRC يومياً.

• لماذا ليس (أ): خرافة: السياسة خطوة أولى.

• لماذا ليس (ج): خرافة: توجد وظائف مبتدئة، والمشاريع العملية تعوض جزءاً من الخبرة.

4. لماذا تحتاج رُفاد إلى GRC وهي غير ملزمة بـ ECC؟

الإجابة: (ب) لأن نظام حماية البيانات الشخصية ينطبق عليها، وعملاؤها يطلبون إثباتاً

• لماذا: الالتزام يأتي من الأنظمة والعقود، والثقة تحتاج دليلاً.

• لماذا ليس (ج): ECC تلزم الجهات الحكومية والتابعة لها وجهات البنية التحتية الوطنية الحساسة.

التمرين 2: المفهوم والخطر والضابط والدليل

الإجابة في العرض: الشريحة 30.

طريقة الحل

1. حدد المفهوم التقني أولاً: ما الشيء الذي يتحدث عنه الموقف؟

2. اكتب الخطر حدثاً له أثر: ماذا قد يحدث، ولمن؟

3. اختر ضابطاً يعالج السبب، واذكر مرجعه إن وُجد.

4. اختر دليلاً يمكن طلبه ورؤيته، ويثبت أن الضابط يعمل لا أنه مكتوب فقط.

المفهوم	الخطر	الضابط	الدليل
1. فصل المهام	موظف واحد يغيّر الحساب البنكي ثم يعتمد المسير، فيحوّل راتباً إلى حساب آخر دون أن يُكتشف.	فصل التعديل عن الاعتماد، وموافقة ثانية على تغيير الحساب البنكي، وتقرير شهري بالتغييرات.	مصفوفة الأدوار في النظام، وتقرير بمن يجمع الصلاحيتين، وعينة من تغييرات الحسابات البنكية بموافقاتها.
2. إدارة التغيير وفصل البيئات	تغيير غير مختبر يوقف خدمة يعتمد عليها العملاء، أو يفتح ثغرة.	إجراء تغيير: طلب، وتقييم أثر، واعتماد، واختبار في بيئة غير الإنتاج، ونافذة تنفيذ محددة.	تذكرة التغيير بموافقتها ونتيجة اختباره، ومطابقة سجل تغييرات الخادم بالتذاكر.
3. السجلات	حادثة قديمة لا يمكن التحقيق فيها، ودخول مشبوه لا يكتشفه أحد.	حفظ السجلات 12 شهراً على الأقل (ECC 2-12-3-5)، ومراقبة مستمرة أو مراجعة منتظمة للتنبيهات.	إعداد مدة الحفظ في الخدمة، وأقدم سجل متاح، وتقرير المراقبة أو المراجعة.

متى تكون إجابتك مقبولة وإن اختلفت

- أي ضابط مناسب يعالج السبب، مع دليل يثبت تشغيله.
- في الموقف الثاني، «فصل البيئات» وحده يكفي إن ذكرت أن التحديث لم يُختبر قبل الإنتاج.

أخطاء شائعة

- اختيار السياسة دليلاً: تثبت التوثيق لا التشغيل.
- كتابة الثغرة بدل الخطر : لا توجد موافقة ثانية» ثغرة، والخطر ما قد يحدث بسببها.

اختبار الوحدة 02: الأساس التقني

1. أدخل الموظف كلمة المرور ورمز التطبيق بنجاح. ماذا أثبت حتى الآن؟

الإجابة: (أ) المصادقة: هويته

- لماذا: المصادقة تجيب عن «من أنت؟». ما يُسمح لك به يحدده دورك وصلاحياته بعد ذلك.
- لماذا ليس (ج): شخص موثّق الهوية قد لا يملك صلاحية لما يطلبه.

2. أي حالة تخالف فصل المهام؟

الإجابة: (ب) موظف يعدّل الحساب البنكي ويعتمد مسير الرواتب

- لماذا: شخص واحد يكمل عملية حساسة من أولها إلى آخرها.
- لماذا ليس (ج): هذه صلاحية يحتاجها لعمله؛ السؤال فيها عن أقل صلاحية، لا فصل المهام.

3. نظام الرواتب خدمة سحابية SaaS. من المسؤول عن مراجعة من يملك صلاحية «تعديل الرواتب»؟

الإجابة: (ب) رُفاد

- لماذا: في كل النماذج تبقى الهويات والصلاحيات والبيانات مسؤولية الجهة.
- لماذا ليس (أ): المزود يوفر أداة الصلاحيات، ولا يعرف من يحتاج ماذا في رُفاد.

4. أي دليل يثبت أن النسخ الاحتياطي يُستعاد فعلاً؟

الإجابة: (ب) محضر اختبار استعادة بتاريخه ونتيجته

- لماذا: وجود النسخة لا يعني أنها تُستعاد.

- لماذا ليس (أ): يثبت أن النسخ أُخذت، لا أنها صالحة.
- لماذا ليس (ج): يثبت التوثيق فقط.

5. كيف تتحقق أن تغييرات الخادم مرت بإدارة التغيير؟

الإجابة: (ب) تطابق سجل التغييرات بتذاكر التغيير المعتمدة

- لماذا: كل سطر في السجل يجب أن تقابله تذكرة معتمدة، كما رأيت في سجل VPN.
- لماذا ليس (أ): المقابلة تساعد على الفهم ولا تثبت.
- لماذا ليس (ج): الإجراء يثبت التصميم لا التشغيل.

التمرين 3: حوكمة أم إدارة أم تشغيل؟

الإجابة في العرض: الشريحة 36.

طريقة الحل

1. حوكمة: من يحدد الاتجاه، ويعتمد القرار، ويشرف ويسائل.

2. إدارة: من يحول القرار إلى خطة وموارد وجدول.

3. تشغيل: من ينفذ العمل اليومي.

4. اسأل عن كل نشاط: من يقوم به، ولمن، ولأي غرض؟

الإجابة النموذجية

#	النشاط	المستوى	السبب
1	اعتماد قرار: «التحقق متعدد العوامل إلزامي للدخول عن بعد»	حوكمة	قرار وتوجه يعتمده صاحب الصلاحية.
2	خطة نشر التحقق متعدد العوامل خلال 6 أسابيع وميزانيتها	إدارة	تخطيط الموارد والجدول لتنفيذ القرار.
3	تسجيل جهاز الموظف في تطبيق التحقق	تشغيل	تنفيذ يومي للإجراء.
4	تقرير ربع سنوي للجنة عن نسبة الحسابات المفعّل عليها التحقق	حوكمة	متابعة وإشراف ومساءلة من الجهة الأعلى.

متى تكون إجابتك مقبولة وإن اختلفت عن النموذج

- النشاط 4: إعداد التقرير نفسه عمل إداري. إن كتبت «إدارة» وذكرت أن عرضه على اللجنة للمتابعة والمساءلة حوكمة، فقد فهمت الفكرة.

أخطاء شائعة

- اعتبار كل تقرير عملاً إدارياً: الحاسم من يستقبله ولماذا. تقرير يُعرض على اللجنة لتتابع وتحاسب أداة حوكمة.
- اعتبار خطة النشر حوكمة لأنها مهمة: الخطة تنفذ قراراً اتُّخذ، فهي إدارة.

التمرين 4: التطبيق 1: تحديد المسؤوليات وصياغة بند سياسة

الإجابة في العرض: الشرائح 54 إلى 56.

طريقة الحل

1. اقرأ المتطلب كلمة كلمة: ECC 1-9-5 يطلب «مراجعة وإلغاء» الصلاحيات، و«مباشرة» بعد انتهاء العلاقة. الكلمتان تحددان ما سيُدقق.

2. ارسم العملية من الحدث إلى الدليل: من يعرف أولاً أن الموظف سيغادر؟ من يلغي؟ أين يُوثق الإلغاء؟ من يتأكد أنه لم يفت شيء؟

3. اكتب الأنشطة بأفعال واضحة. خمسة أنشطة تكفي: إشعار، وإلغاء، وتوثيق، ومطابقة، ومراقبة.

4. لكل نشاط: من ينفذ (R)؟ ومن يُحاسَب على النتيجة (A)؟ ثم من يُستشار (C) ومن يُبلَّغ (I). وتأكد من A واحد.

5. اكتب البند بمعايير البند الجيد: النطاق، والمسؤول، والموعد، والصيغة الإلزامية، والدليل.

6. اختبر البند: لو جاء مدقق غداً، ما الدليل الذي سيطلبه؟ إن لم تجد دليلاً فالبند غامض.

الإجابة النموذجية: مصفوفة RACI

النشاط	الموارد البشرية	مدير الموظف	تقنية المعلومات	GRC
إشعار انتهاء العلاقة الوظيفية فور تحديد آخر يوم عمل	A/R	C	I	
إلغاء الحسابات والصلاحيات في كل الأنظمة	I	I	A/R	
توثيق الإلغاء في تذكرة مغلقة بأدلتها	I		A/R	I
مطابقة شهرية: المغادرون مقابل الحسابات النشطة	C		A/R	I
مراقبة فاعلية الإجراء وإبلاغ اللجنة	C		C	A/R

الإجابة النموذجية: بند السياسة

يجب إلغاء جميع حسابات العامل وصلاحياته في أنظمة رُفاد، بما فيها حسابات الوصول عن بعد، في موعد أقصاه نهاية آخر يوم عمل له. تُشعر الموارد البشرية تقنية المعلومات فور تحديد آخر يوم عمل، وتنفذ تقنية المعلومات الإلغاء وتوثقه في تذكرة، وتطابق شهرياً قائمة المغادرين مع الحسابات النشطة.

لماذا هذه الإجابة

- الموارد البشرية مصدر الحقيقة عن انتهاء العلاقة الوظيفية، فهي A وR للإشعار.
- التنفيذ عند تقنية المعلومات، والمورد ينفذ تحت إشرافها؛ المسؤولية لا تنتقل إلى المورد.
- المطابقة الشهرية ضابط كشفي يلتقط ما فات، ويملكه الخط الأول لا GRC.
- GRC يراقب ويبلغ، ولا ينفذ الإلغاء بنفسه حتى يبقى قادراً على التحقق باستقلالية.
- البند يحدد النطاق والموعد والمسؤول والدليل، فيمكن تدقيقه.

متى تكون إجابتك مقبولة وإن اختلفت عن النموذج

- الموعد: «نهاية آخر يوم عمل» قرار رُفاد. موعد قصير محدد آخر مقبول إن ربطته بمعنى «مباشرة» وبحساسية الأنظمة. «في الوقت المناسب» غير مقبول.
- قد يكون مدير الموظف هو المنفذ R للإشعار في بعض الجهات، ما دامت الموارد البشرية مصدر الحقيقة ويبقى A واحد.
- إن وضعت المورد سَنَد منفذاً لإلغاء البريد تحت إشراف تقنية المعلومات فهذا صحيح، بشرط أن يبقى A في رُفاد.
- صياغتك للأنشطة قد تختلف. المهم أن تغطي الإشعار والإلغاء والتوثيق والتحقق.

أخطاء شائعة

- وضع GRC مسؤولاً عن تعطيل الحسابات.
- أكثر من A في النشاط الواحد، أو نشاط بلا A.
- بند غامض: «تُلغى الصلاحيات في الوقت المناسب».
- نسيان حسابات الوصول عن بعد ونظام الرواتب وتطبيق التتبع.
- نسخ نص الضابط كما هو دون تحديد من ومتى وما الدليل.

التمرين 5: من هدف «صحة الرواتب» إلى قرار الإدارة

الإجابة في العرض: الشريحة 73.

طريقة الحل

1. ابدأ من هدف العمل بكلمات الإدارة، لا من الثغرة.
2. حدد الأصل الذي يخدم الهدف، ثم الخطر عليه بصيغة السبب والحدث والأثر.
3. اختر ضابطاً يعالج السبب، وحدد مالكاً واحداً.
4. اختر مؤشراً يقيس التعرض للخطر أو عمل الضابط، بحد واضح.
5. اكتب القرار الذي يحتاجه الأمر من صاحب الصلاحية، وكلفته.

هدف العمل	صرف رواتب صحيحة إلى الحسابات الصحيحة في موعدها.
الأصل الداعم	نظام الموارد البشرية والرواتب، وبيانات الحسابات البنكية فيه.
الخطر	بسبب جمع موظف واحد لتعديل الحساب البنكي واعتماد المسير، قد يُحوَّل راتب إلى حساب غير صحيح دون اكتشاف، مما يسبب خسارة مالية وتأخر راتب موظف ومساءلة داخلية.
الضابط	فصل المهام: من يعدّل لا يعتمد، وموافقة ثانية على تغيير الحساب البنكي، وتقرير شهري بالتغييرات يراجعه المدير المالي.
المالك	مالكة الخطر والنظام: أ. منى. ومراجعة التقرير الشهري: أ. فهد.
المؤشر	عدد تغييرات الحسابات البنكية بلا موافقة ثانية في الشهر. الحد المقبول: صفر.
القرار المطلوب	اعتماد إعادة توزيع الأدوار في الموارد البشرية، وقبول تأخير قصير في التعديلات بسبب الموافقة الثانية.

الأثر بلغة الأعمال: تكلفة مالية، وتأخير عمليات الصرف، ومساءلة داخلية.

متى تكون إجابتك مقبولة وإن اختلفت

- مؤشر ضابط بدل مؤشر الخطر، مثل «نسبة التغييرات بموافقة ثانية»، إن كتبت غرضه.
- جعل المدير المالي مالكاً للمؤشر مقبول إن بقيت منى مالكة الخطر والنظام.

أخطاء شائعة

- جعل GRC مالكة الخطر.
- قرار بلا كلفة: «تحسين الضوابط».
- أثر تقني: «ضعف في الصلاحيات».

التمرين 6: التطبيق 2: كتابة خطر وتقييمه وتحديد معالجته

الإجابة في العرض: الشرائح 80 إلى 83.

طريقة الحل

1. حدد الأصل والبيانات: خادم تطبيق التتبع، وعليه بيانات نحو 50 ألف مستلم شهرياً.

2. افصل الثغرة عن الخطر: الحساب المشترك وغياب التحقق متعدد العوامل والأداة المكشوفة ثغرات. الخطر هو ما قد يحدث بسببها.

3. اكتب الخطر بالصيغة: بسبب (الثغرة)، قد (الحدث)، مما يؤدي إلى (الأثر).

4. اكتب الضوابط الحالية كما هي فعلاً، حتى الضعيفة منها لا تكتب ضابطاً غير موجود.

5. اختر الاحتمال من مقياس الاحتمال، بالإطار الزمني أو بسهولة الاستغلال، واكتب لماذا لم تختر الدرجة التي فوقها.

6. اختر الأثر من مقياس الأثر بالطريقة نفسها، ثم احسب المستوى: الاحتمال × الأثر، وحدد نطاقه.

7. طبّق قاعدة القبول في رُفاد: المستوى العالي يعني معالجة إلزامية وعرضاً على اللجنة.

8. لكل إجراء: ماذا يقلل؟ الاحتمال أم الأثر؟ ثم قدّر المتبقي بافتراضات مكتوبة.

الإجابة النموذجية

وصف الخطر	بسبب استخدام حساب إداري مشترك لمورد الدعم عبر أداة وصول عن بعد مكشوفة على الإنترنت بلا تحقق متعدد العوامل، قد يستخدم مهاجم كلمة مرور مسربة أو مخمّنة للدخول إلى خادم تطبيق التتبع، مما يؤدي إلى تسرب البيانات الشخصية للمستلمين أو تعطيل خدمة التتبع.
الضوابط الحالية	كلمة مرور قديمة، وبند سرية في العقد، وسجلات جلسات 30 يوماً بلا مراجعة.
الاحتمال	4: «محتمل»: الاستغلال سهل متى عُرفت كلمة المرور، وهي مشتركة بين 5 أشخاص ولم تتغير منذ سنوات. لم نختر 5 لأن المهاجم يحتاج أولاً إلى كلمة المرور، ولا توجد ثغرة منشورة تتجاوزها.
الأثر	4: «عالٍ»: تسرب بيانات شخصية لعشرات الآلاف مع احتمال توقف الخدمة، بأثر كبير على رُفاد. لمَ نختر 5 لأن الأثر لا يمتد إلى المستوى الوطني.
المستوى	4 × 4 = 16 · عالٍ
مالك الخطر	مدير تقنية المعلومات
خيار المعالجة	التخفيف، مع بنود تعاقدية عند التجديد. المسؤولية لا تنتقل إلى المورد.

الإجراء	المالك	الموعد
حسابات فردية لكل فني وإلغاء الحساب المشترك	مدير تقنية المعلومات	14 يوماً
تفعيل التحقق متعدد العوامل على أداة الوصول (ECC 2-2-3-2)	مدير تقنية المعلومات	14 يوماً
إيقاف الوصول الدائم: وصول عند الطلب بموافقة	مدير تقنية المعلومات	30 يوماً
مراجعة أسبوعية لسجلات الجلسات	مدير تقنية المعلومات	30 يوماً
إضافة بنود ECC 4-1-2 عند تجديد العقد	المدير المالي	عند التجديد

المتبقي المتوقع	2 × 4 = 8 · متوسط
لماذا	بعد الإجراءات يصبح الاحتمال «نادراً» (2) لأن كلمة المرور وحدها لا تكفي. الأثر يبقى «عالياً» (4) لأن البيانات نفسها ما زالت على الخادم. النتيجة 8: «متوسط».
القرار	المتوسط يحتاج قراراً: قبول موثق من الرئيس التنفيذي، أو معالجة إضافية مثل حصر الوصول بعناوين المورد المعتمدة.

طلب التمرين ثلاثة إجراءات، والنموذج فيه خمسة. أهم ثلاثة: الحسابات الفردية، والتحقق متعدد العوامل، والوصول عند الطلب بموافقة.

لماذا هذه الإجابة

• لا يوجد تحقق متعدد العوامل» ثغرة، وليست خطراً كاملاً. الخطر يربط الثغرة بحدث وأثر.

• كل درجة لها مبرر مأخوذ من أوصاف المصفوفة، لا من الانطباع.

- التحقق متعدد العوامل يقلل الاحتمال ولا يغير الأثر.
- المعالجة عند الخط الأول، وGRC يتابع، والمورد لا يملك الخطر.

متى تكون إجابتك مقبولة وإن اختلفت عن النموذج

- الاحتمال 5 مقبول إن بررته بأن الأداة مكشوفة وتخمين كلمة مرور قديمة سهل. يصبح المستوى 20 «حرجاً»، والقرار لا يتغير: معالجة إلزامية وعرض على اللجنة.
- الاحتمال 3 ضعيف المبرر هنا: كلمة المرور مشتركة بين خمسة ولم تتغير منذ 2023، والوصول مفتوح على مدار الساعة.
- الأثر 5 يحتاج مبرراً بأن الأثر لا تحتمله رُفاد أو يمتد وطنياً، والبيانات لا توحي بذلك.
- المتبقي 3 × 4 = 12 مقبول إن افترضت تطبيقاً جزئياً للإجراءات. غير المقبول: تخفيض الأثر دون إجراء يقلل البيانات نفسها، أو متبقٍ بلا افتراضات.

أخطاء شائعة

- كتابة الثغرة وحدها خطراً : لا يوجد MFA».
- درجات بلا تبرير، أو خلط الاحتمال بالأثر.
- افتراض أن الخطر يصبح «منخفضاً جداً» تلقائياً بعد أي ضابط.
- اختيار «النقل إلى المورد» معالجة؛ المسؤولية لا تنتقل.
- إجراءات بلا مالك أو موعد، أو مالكها GRC.

التمرين 7: التطبيق 3: فحص أدلة ضابط وتحديد نتيجة التقييم

الإجابة في العرض: الشرائح 109 إلى 114.

طريقة الحل

1. ثبّت ما تقيسه: المتطلب، والنطاق (نظام الرواتب)، والفترة (1 يناير إلى 30 يونيو 2026)، والمعيار الداخلي بمهله.

2. لكل دليل اسأل: ماذا يثبت؟ التوثيق (المتطلب مكتوب)، أم التطبيق (نُفذ مرة)، أم الاستمرار (نُفذ طوال الفترة)؟

3. اقرأ التواريخ واحسب المهل بأيام العمل. التصدير 29 مارس والاعتماد 8 أبريل: 8 أيام عمل، ضمن مهلة 10. مهلة الإزالة تنتهي 15 أبريل: 9 إزالات حتى 12 أبريل ضمنها، و3 في 20 مايو متأخرة نحو 6 أسابيع.

4. فرّق بين الحقيقة والادعاء: البريد يدّعي سبب التأجيل، والمقابلة تصف ممارسة. كلاهما يحتاج تحققاً.

5. طبّق المقياس على الفترة كاملة: هل كل المطلوب مثبت طوال الفترة؟ إن ثبت جزء وغاب جزء فالنتيجة «مطبق جزئياً».

6. اكتب ما تحتاجه قبل الإغلاق: أدلة تؤكد السبب، أو تكشف استثناءً معتمداً، أو تنفيذاً متأخراً.

الإجابة النموذجية: ماذا يثبت كل دليل

الدليل	ماذا يثبت
د1	التوثيق: المتطلب موثق ومعتمد.
د2	التطبيق: المراجعة نُفذت واعتُمدت في موعدها للربع الأول.
د3	الاستمرار: 3 إزالات متأخرة عن مهلة 5 أيام عمل.
د4	الاستمرار: الربع الثاني لم يُنفذ. السبب ادعاء لم نتحقق منه بعد.
د5	نتيجة فعلية: صلاحيات غير مبررة بقيت نشطة.
د6	لا تثبت شيئاً وحدها، لكنها تكشف فجوة وعي بالمعيار.

الإجابة النموذجية: الأسئلة الأربعة للمقتطفات (الشرائح 110 إلى 112)

الدليل	ما الذي نراه؟	ماذا يثبت؟	ماذا لا يثبت؟	ما المطلوب إضافةً؟
د2	قرار المدير لكل حساب، و12 للإزالة من 214، واعتماد مالكة النظام في 8 أبريل.	نُفذت المراجعة واعتُمدت في موعدها: 8 أيام عمل من التصدير، والمهلة 10.	أن الإزالات نُفذت. قرار الإزالة ليس إزالة.	تذاكر الإزالة.
د3	طلب إزالة «تعديل الرواتب» من hr.s.dosari: فُتح 8 أبريل، وأُغلق 20 مايو.	نُفذت الإزالة بعد نحو 6 أسابيع، والمهلة تنتهي 15 أبريل.	سبب التأخير. ملاحظة الإغلاق لا تذكره.	سبب تأخر الإزالات الثلاث، من تذاكرها أو من تقنية المعلومات.
د5	ياسر القحطاني ولمى الشمري غادرا في مايو، وحساباهما نشطان في 2 يوليو.	بقاء صلاحيات غير مبررة لحسابين بعد المغادرة.	أنهما استُخدما بعد المغادرة، ولا حالة بقية المغادرين، فالمقتطف 5 صفوف.	مطابقة كل المغادرين بالتصدير الكامل، وسجل نشاط الحسابين، وإبلاغ مالك الضابط 5-9-1.

النتيجة: مطبق جزئياً. المتطلب موثق (د1) وطُبق في الربع الأول (د2)، لكنه لم يعمل باستمرار: الربع الثاني لم يُنفذ (د4)، و3 إزالات تأخرت (د3)، وبقيت صلاحيات غير مبررة (د5). اختيار «مطبق» يتجاهل نصف الفترة، واختيار «غير مطبق» يتجاهل ما نُفذ فعلاً.

أدلة إضافية قبل الإغلاق

- سجل تغيير ترحيل النظام لتأكيد التاريخ وهل منع المراجعة فعلاً.
- هل اعتُمد استثناء بتأجيل المراجعة وموعد بديل؟
- هل نُفذت مراجعة الربع الثاني لاحقاً في يوليو؟
- سبب تأخر الإزالات الثلاث من تذاكرها.

تنبيه: الدليل د5 مؤرخ بعد نهاية الفترة بيومين، لكنه يكشف حالة بدأت داخلها: مغادرو مايو. وهو يشير أيضاً إلى

ضعف في إلغاء صلاحيات المغادرين، وهو ضابط التطبيق 1 (ECC 1-9-5). سجّله ملاحظة مرتبطة، ولا تخلط الضابطين في نتيجة واحدة.

متى تكون إجابتك مقبولة وإن اختلفت عن النموذج

- صياغة المبرر قد تختلف، بشرط أن تذكر ما ثبت (التوثيق، وتنفيذ الربع الأول) وما لم يثبت (الربع الثاني، والإزالات المتأخرة، والحسابات النشطة).
- «غير مطبق» غير مقبول هنا: يتجاهل مراجعة نُفذت واعتُمدت في موعدها.
- «مطبق» غير مقبول: وجود المعيار وتنفيذ ربع واحد لا يثبتان الاستمرار طوال الفترة.

أخطاء شائعة

- «مطبق» لأن المعيار موجود: الوثيقة لا تثبت التشغيل.
- «غير مطبق» مع تجاهل الربع الأول.
- الاعتماد على المقابلة وحدها دليلاً.
- تعميم: «كل الإزالات متأخرة» من 3 حالات من 12.
- اعتبار سبب البريد مؤكداً دون تحقق.

التمرين 8: ما نوع الفجوة؟

الإجابة في العرض: الشريحة 119.

طريقة الحل

1. اسأل عن التصميم: لو نُفذ الضابط بإتقان، هل يغطي الخطر والنطاق؟
2. إن كان التصميم سليماً، اسأل: هل طُبق مرة على الأقل؟
3. إن طُبق، اسأل: هل عمل بالتكرار المطلوب طوال الفترة؟
4. اختر الدليل الذي يثبت الإجابة عن السؤال الذي توقفت عنده.

#	النوع	لماذا	الدليل
1	فجوة تصميم	الضابط كما كُتب يترك باباً مفتوحاً: استثناء بلا موافقة ولا مدة. هذا ما سمح بسياسة VPN-Legacy في التطبيق 3.	نص المعيار، وقائمة الاستثناءات القائمة وتواريخها.
2	فجوة تنفيذ	المتطلب مكتوب ومعتمد، لكنه لم يُطبق على العقد القائم.	السياسة المعتمدة، وعقد سَنَد الحالي، وأي مراسلة أو خطة لتعديله.
3	فجوة تشغيل	الضابط مصمم ومطبق، لكنه توقف 9 أيام دون أن يلاحظ أحد.	تقرير مهام النسخ للفترة كلها، وتذاكر المتابعة إن وُجدت.

ملاحظة: المعيار في الموقف الأول يخالف أيضاً السياسة POL-AC-01 التي تطلب موافقة ومدة لكل استثناء. وهذا من أسباب الملاحظة F-03.

أخطاء شائعة

- تسمية كل فجوة «فجوة تشغيل».
- الحكم على الموقف الثاني بأنه تشغيل: الضابط لم يبدأ أصلاً على العقد القائم.

التمرين 9: التطبيق 4: كتابة ملاحظة وخطة تصحيح

الإجابة في العرض: الشرائح 127 إلى 130.

طريقة الحل

1. ابدأ من نتيجة التطبيق 3 وأدلتها. الملاحظة لا تضيف حقائق جديدة، بل ترتب ما ثبت.

2. العنوان: الفجوة في سطر واحد، بلا لوم ولا مبالغة.

3. الوضع القائم: أرقام وتواريخ من الأدلة فقط: «3 من 12»، لا «بعض».

4. المعيار: الضابط، والمعيار الداخلي بمهله.

5. السبب: ما تحققت منه. هنا تحققت من سجل الترحيل ولم تجد استثناءً معتمداً. وإن لم تتحقق فاكتب «سبب محتمل».

6. الأثر: ماذا يعني للجهة بلغة يفهمها مدير غير تقني.

7. التوصية: ما يعالج السبب. ثم فصّلها في خطة تصحيح: إجراء فوري يزيل الخطر، وإجراءات تمنع التكرار.

8. لكل إجراء: مالك واحد بالوظيفة، وموعد، ودليل إغلاق. ثم حدد متى يُعاد الاختبار.

الإجابة النموذجية: الملاحظة

رقم الملاحظة	F-04
الضابط	ECC 2-2-3-5
الفترة	1 يناير إلى 30 يونيو 2026
العنوان	عدم انتظام المراجعة الدورية لصلاحيات نظام الموارد البشرية والرواتب
الوضع القائم	نُفذت مراجعة الربع الأول واعتُمدت في موعدها، لكن 3 من 12 إزالة نُفذت بعد 6 أسابيع، ولم تُنفذ مراجعة الربع الثاني حتى 30 يونيو 2026. وفي 2 يوليو كان حسابان لموظفين غادروا في مايو ما زالا نشطين.
المعيار	ECC 2-2-3-5، ومعيار التحكم بالوصول (يناير 2026): مراجعة كل 3 أشهر، وإزالة خلال 5 أيام عمل.
السبب	أُجّلت مراجعة الربع الثاني بسبب ترحيل النظام دون استثناء معتمد أو موعد بديل، ولا توجد متابعة لتذاكر الإزالة المتأخرة. تحققنا من ذلك بسجل الترحيل وتذاكر الإزالة.
الأثر	بقاء صلاحيات غير مبررة على رواتب الموظفين وحساباتهم البنكية، منها حسابان لمغادرين.
التوصية	تعطيل حسابي المغادرين فوراً، وإكمال مراجعة الربع الثاني، واعتماد جدول مراجعات ببديل معتمد عند التعارض، ومتابعة تذاكر الإزالة. التفاصيل في خطة التصحيح.

الإجابة النموذجية: خطة التصحيح

الإجراء	النوع	المالك	الموعد	دليل الإغلاق
تعطيل حسابي المغادرين ومراجعة نشاطهما بعد المغادرة	معالجة الحالة	مدير تقنية المعلومات	يوما عمل	تصدير الحسابات، ونتيجة مراجعة السجل
تنفيذ مراجعة الربع الثاني واعتمادها	معالجة الحالة	مديرة الموارد البشرية	15 يوم عمل	ملف المراجعة المعتمد، وتذاكر الإزالة
جدول مراجعات سنوي بتذكير آلي وبديل معتمد عند التعارض	منع التكرار	مديرة الموارد البشرية	30 يوماً	الجدول المعتمد، وإعداد التذكير
متابعة أسبوعية لتذاكر الإزالة المفتوحة	منع التكرار	مدير تقنية المعلومات	فوراً	تقرير التذاكر الأسبوعي

إعادة الاختبار: تعيد GRC الاختبار بعد مراجعة الربع الثالث، ولا تُغلق الملاحظة إلا بأدلة الإغلاق.

لماذا هذه الإجابة

- الوضع القائم أرقام وتواريخ، لا أحكام عامة.
- السبب مُتحقق منه، ويعالج العملية لا الأشخاص.
- كل إجراء له مالك واحد باسم الوظيفة، وموعد، ودليل إغلاق.

• إجراء فوري لإزالة الخطر، وإجراءات تمنع التكرار.

متى تكون إجابتك مقبولة وإن اختلفت عن النموذج

• المواعيد تقديرات تخطيط. المهم أن يكون الإجراء الفوري قصيراً جداً، وأن تكون المواعيد الأخرى واقعية ومحددة.
• مالك الجدول قد يكون تقنية المعلومات إن كان التذكير آلياً في النظام، ما دامت مالكة النظام تعتمد المراجعة.
• إن قررت الإدارة قبول الخطر بدل بعض الإجراءات، يوثق القرار صاحب الصلاحية، ولا يلغي ذلك الالتزام بالضابط.

أخطاء شائعة

• لوم شخص بالاسم بدل العملية.
• مالك عام: «تقنية المعلومات» أو «الجميع».
• إجراء بلا موعد أو دليل إغلاق.
• الاكتفاء بتوصية «تدريب الموظفين».
• إغلاق الملاحظة بوعد بدل دليل.

التمرين 10: صنّف المؤشرات وعرّف واحداً

الإجابة في العرض: الشريحة 136.

طريقة الحل

1. اسأل عن الغرض: هدف عمل، أم أداء عملية، أم تعرض لخطر، أم عمل ضابط؟

2. إن صلح المؤشر لأكثر من غرض، اختر واكتب الغرض في تعريفه.

3. عرّف المؤشر بالأسئلة الستة قبل أن تجمع أي رقم.

#	النوع	لماذا
1	KGI	يقيس تحقق هدف عمل: التوصيل في الموعد.
2	KRI	يقيس تعرضاً للخطر: كل حساب منها باب مفتوح لشخص خارج الشركة.
3	KCI	يقيس هل يعمل ضابط MFA على كل الاتصالات، كما رأيت في التطبيق 3.
4	KPI أو KCI	يعتمد على الغرض: إن كان لمتابعة عملية التهيئة فهو KPI، وإن كان لإثبات أن ضابط التوعية يعمل فهو KCI. اكتب الغرض في تعريفه.

تعريف المؤشر الثاني (KRI)

ماذا يقيس؟	من غادر وما زال حسابه نشطاً في نظام الرواتب.
طريقة الحساب	عدد الحسابات النشطة لأصحابها في قائمة المغادرين.
المصدر	قائمة المغادرين من الموارد البشرية، وتصدير الحسابات النشطة.
المالك	أ. منى، وتقنية المعلومات تعطّل.
الدورية	شهري
ما يستدعي إجراءً	أي رقم أكبر من صفر: تعطيل خلال يوم عمل، وإبلاغ مالك ضابط المغادرين.

أخطاء شائعة

- تصنيف المؤشر من اسمه لا من غرضه.
- مؤشر بلا حد يستدعي إجراءً: رقم يُجمع ولا يُستخدم.

اختبار الوحدة 03: المفاهيم وتطبيقاتها

1. في مصفوفة RACI، كم «A» في كل نشاط؟

الإجابة: (أ) واحد فقط

- لماذا: شخص واحد يُحاسَب على النتيجة.
- لماذا ليس (ب): تعدد A يضيّع المساءلة.

2. أي صياغة خطر أفضل؟

الإجابة: (ب) بسبب غياب MFA على VPN، قد تُستغل كلمة مرور مسروقة للدخول، مما يؤدي إلى الاطلاع على بيانات الرواتب

- لماذا: سبب، وحدث، وأثر.
- لماذا ليس (أ): هذه ثغرة، لا خطر.
- لماذا ليس (ج): عامة بلا سبب ولا أثر.

3. الخطر المتبقي هو:

الإجابة: (ب) الخطر بعد الضوابط المنفذة فعلاً

- لماذا: يُقدَّر بعد الضوابط، وبافتراضات مكتوبة عن فاعليتها.
- لماذا ليس (أ): هذا المتأصل.

4. إجراء مراجعة يستثني الحسابات الإدارية بنصه. ما نوع الفجوة؟

الإجابة: (أ) تصميم

- لماذا: الضابط كما صُمّم لا يغطي النطاق المطلوب.

• لماذا ليس (ج): التشغيل يُسأل عنه بعد التأكد أن التصميم يغطي الخطر.

5. «نسبة المراجعات المعتمدة في موعدها» أقرب إلى:

الإجابة: (ب) KCI

• لماذا: يقيس هل يعمل ضابط المراجعة.

• لماذا ليس (أ): KRI يقيس التعرض للخطر نفسه.

التمرين 11: ما الذي ينطبق على كل جهة؟

الإجابة في العرض: الشريحتين 154 و155.

طريقة الحل

1. اسأل أربعة أسئلة عن الجهة: هل هي حكومية أو تابعة لجهة حكومية أو خاصة؟ ما قطاعها ومن ينظمها؟ ما نوع البيانات التي تعالجها؟ ما عقودها والتزاماتها؟

2. اقرأ نطاق كل إطار من نصه الرسمي، لا من اسمه أو شهرته.

3. فرّق بين «ملزم» و«متبنى طوعاً» و«يعتمد على» شرط تذكره.

الإجابة النموذجية

الجهة	ECC-2:2024	نظام حماية البيانات الشخصية	إطار ساما للأمن السيبراني	PCI DSS
رُفاد	غير ملزم؛ تبنته طوعاً	نعم	لا	لا، ما دامت لا تخزن بيانات البطاقات أو تعالجها أو تنقلها
مدى التقنية	نعم: تابعة لجهة حكومية	نعم إن عالجت بيانات شخصية	لا	حسب معالجتها للبطاقات
دفع سريع	لا، ما لم تكن حكومية أو بنية تحتية حساسة	نعم	غالباً نعم: تحقق من نطاق الإطار في دليل ساما	نعم: تعالج بيانات البطاقات

لماذا هذه الإجابة

- الانطباق يُحدَّد من النص الرسمي لنطاق كل إطار، لا من اسمه.
- النوع (حكومي أو خاص)، والقطاع، ونوع البيانات، والعقود: أربعة أسئلة تكفي للبداية.
- الإطار غير الملزم يمكن تبنيه طوعاً، لكن لا تصف الجهة بأنها «ملتزمة نظاماً» به.

متى تكون إجابتك مقبولة وإن اختلفت عن النموذج

- «يعتمد» مقبول في أي خانة إن ذكرت الشرط الصحيح، مثل: PCI DSS لرُفاد يعتمد على تخزين بيانات البطاقات أو معالجتها أو نقلها.
- إطار ساما: تحقق من نطاقه في وثيقته الرسمية لدى البنك المركزي السعودي قبل الجزم.

أخطاء شائعة

- افتراض أن ECC تلزم كل شركة سعودية.
- نسيان نظام حماية البيانات الشخصية لأن الجهة ليست تقنية.
- الجزم بالانطباق دون الرجوع إلى نص النطاق.

التمرين 12: مواءمة مراجعة الصلاحيات مع مرجعين

الإجابة في العرض: الشريحة 158.

طريقة الحل

1. اقرأ ما يطلبه كل مرجع بنصه، لا بعنوانه.
2. قارن نطاق الضابط الداخلي بنطاق المتطلب: الأنظمة، والحسابات، وخطوات دورة الحياة.
3. احكم: كلي أم جزئي، واكتب ما ينقص.
4. حدد الأدلة المشتركة، وتذكر أن المواءمة لا تثبت التشغيل.

المرجع	التغطية	لماذا
ECC 2-2-3-5	جزئي	الضابط يغطي نظام الرواتب، ثم تطبيق التتبع من الإصدار 1.1. البريد يغطيه إجراء آخر بفجوة في الحسابات الإدارية، وVPN بلا مراجعة.
ISO A.5.18	جزئي	الضابط يخدم المراجعة والإزالة، ولا يغطي منح الصلاحيات وتعديلها.
الأدلة	مشتركة	ملف المراجعة واعتماده يخدمان المراجعة في المرجعين، وتذاكر الإزالة تخدم الإزالة في ISO.

تنبيه: عناوين ضوابط ISO/IEC 27001:2022 مذكورة بإيجاز. طابقها مع نسختك المرخصة من المعيار قبل الاستشهاد بنصها.

أخطاء شائعة

- كتابة «متوافق» لأن العنوانين متشابهان.
- نسيان أن الضابط نفسه فيه فجوة تشغيل، فالمواءمة لا تعني الالتزام.

اختبار الوحدة 04: الأطر والانطباق

1. هل ECC-2:2024 ملزمة لشركة توصيل خاصة لا تتبع جهة حكومية؟
الإجابة: (ب) لا، ويمكنها تبنيها طوعاً
- لماذا: نطاقها الجهات الحكومية والتابعة لها وجهات البنية التحتية الوطنية الحساسة.
- لماذا ليس (ج)لا يوجد هذا الشرط في نطاقها.

2. ضابط داخلي يشبه ضابطاً في ISO 27001. ماذا تستنتج؟
الإجابة: (ب) تحتاج أن تتحقق: هل يغطي المتطلب كلياً أم جزئياً، وهل يعمل
- لماذا: التشابه بداية المواءمة، لا دليل الالتزام.
- لماذا ليس (أ)لا التزام بلا تغطية مثبتة وأدلة تشغيل.

3. ما الفرق بين NIST CSF وNIST RMF؟
الإجابة: (ب) CSF إطار نتائج للجهة كلها، وRMF عملية من سبع خطوات لإدارة مخاطر نظام
- لماذا: يكمل أحدهما الآخر، ويعملان على مستويين مختلفين.
- لماذا ليس (ج): RMF وثيقة مستقلة: SP 800-37.

4. تقييم الفجوات يجيب عن:
الإجابة: (ب) ما الفرق بين الوضع القائم ومتطلب محدد؟
- لماذا: نتيجته قائمة فجوات مقابل متطلبات.
- لماذا ليس (أ): هذا تقييم النضج.

التمرين 13: اختر الشهادة المناسبة

الإجابة في العرض: الشريحة 178.

طريقة الحل

1. حدد الوظيفة المستهدفة للشخص.
2. حدد خبرته الحالية، وما ينقصه للوظيفة.
3. «الآن»: شهادة لا تشترط خبرة لا يملكها، وتسد ما ينقصه. «لاحقاً»: شهادة سيستوفي شرط خبرتها.
4. تحقق من الشروط في الصفحة الرسمية قبل التسجيل، فهي تتغير.

الإجابة النموذجية

الشخص	الاختيار	السبب
سارة	CC أو Security+ الآن، ثم ISO 27001 Lead Implementer أو CRISC. GRCP أو CGRC لاحقاً بعد اكتمال الخبرة.	شهادة مدخل بلا شرط خبرة، ثم مهارة تطبيقية مطلوبة في الإعلانات.
عبدالله	ISO 27001 Lead Auditor أو IT Audit Fundamentals الآن، وCISA هدفاً قريباً.	خبرته في المراجعة قد تُحتسب لشرط CISA بحسب قواعد ISACA، فتحقق منها. Lead Auditor يبني على مهارة التدقيق لديه.
نورة	CIPP/E أو CIPM الآن، مع قراءة نظام حماية البيانات الشخصية ولوائحه.	خلفيتها القانونية تناسب CIPP/E، وCIPM يضيف إدارة برنامج الخصوصية لا تحتاج شهادة تقنية أولاً.

متى تكون إجابتك مقبولة وإن اختلفت عن النموذج

• أي اختيار آخر مقبول إن طابق الوظيفة المستهدفة، ولم يشترط خبرة لا يملكها الشخص، وبُرر بجملتين.

أخطاء شائعة

• اقتراح CISSP أو CISM أو CISA شهادة أولى لخريج بلا خبرة.
• اختيار الشهادة بالشهرة أو الراتب المتوقع لا بالوظيفة المستهدفة.

اختبار الوحدة 05: الشهادات

1. خريج بلا خبرة يريد وظيفة GRC. أي شهادة أنسب الآن؟
الإجابة: (ب) ISC2 CC أو IT Risk Fundamentals
• لماذا لا تشترط خبرة، وتبني الأساس.
• لماذا ليس (أ): تشترط خبرة سنوات قبل منحها.
• لماذا ليس (ج): تشترط خبرة أيضاً.

2. الفرق بين ISO 27001 Lead Implementer وLead Auditor:
الإجابة: (ب) الأول لبناء نظام الإدارة وتطبيقه، والثاني لتدقيقه
• لماذا: اختر حسب الوظيفة المستهدفة.

3. دورة تُشرح بالعربية تعني أن الاختبار بالعربية:
الإجابة: (ب) غير صحيح؛ تحقق من لغات الاختبار في صفحة الجهة المانحة
• لماذا: لغة التدريب ليست لغة الاختبار.

التمرين 14: صفحة مشروع تقييم الصلاحيات

الإجابة في العرض: الشريحة 186.

طريقة الحل

1. ابدأ بالمشكلة كما يفهمها مدير توظيف: ما السؤال الذي أجاب عنه المشروع؟
2. «ما فعلته» بأفعال وأرقام من التطبيقين 3 و4.
3. النتيجة: ماذا أنتجت؟ وما تعلمته: جملة تبين فهمك لا حماسك.
4. اذكر صراحة أن البيانات افتراضية، وأرفق ملفاتك بلا أي بيانات حقيقية.

الإجابة النموذجية

عنوان المشروع	تقييم مراجعة الصلاحيات في نظام الرواتب، شركة افتراضية
المشكلة	معيار يطلب مراجعة ربع سنوية، ولا نعرف هل تُنفذ فعلاً.
ما فعلته	حللت 6 أدلة، وحددت نتيجة «مطبق جزئياً»، وكتبت ملاحظة وخطة تصحيح بأربعة إجراءات.
النتيجة	ملاحظة واحدة بمالكين ومواعيد وأدلة إغلاق، و4 أسئلة متابعة قبل الإغلاق.
ما تعلمته	وجود المعيار لا يثبت التشغيل، والسبب يحتاج تحققاً قبل كتابته.
الملفات المرفقة	ورقة التقييم، ونص الملاحظة، وخطة التصحيح. كلها ببيانات افتراضية.

أخطاء شائعة

- نشر بيانات أو وثائق حقيقية من جهة عمل أو تدريب.
- وصف عام بلا أرقام: «عملت على تقييم الضوابط».
- تقديم الشركة الافتراضية كأنها جهة حقيقية عملت معها.

اختبار الوحدة 06: خطة البداية وملف الأعمال

1. ماذا تنشر في ملف أعمالك؟
الإجابة: (ب) مشاريعك على حالة افتراضية، مع التصريح بأن بياناتها افتراضية
- لماذا: تعرض مهارتك دون كشف بيانات حقيقية.
- لماذا ليس (أ): نشر وثائق جهة حقيقية مخالفة وخطر.

2. أهم ما في صفحة المشروع:
الإجابة: (ب) المشكلة، وما فعلته بأفعال وأرقام، والنتيجة
- لماذا: هذا ما يقرؤه مسؤول التوظيف في دقيقة.

3. تمرين التطبيق 3 يصبح مشروعاً بعنوان:
الإجابة: (أ) تقييم مراجعة صلاحيات في شركة افتراضية
- لماذا: صادق وواضح.
- لماذا ليس (ب): رُفاد افتراضية؛ تقديمها جهة عمل تضليل.

التمرين 15: أعد صياغة ثلاثة أسطر في السيرة

الإجابة في العرض: الشريحة 196.

طريقة الحل

1. ابدأ بفعل إنجاز، مثل Assessed أو Tested أو Mapped أو Wrote.
2. اذكر ماذا فعلت وعلى ماذا، بحجمه الحقيقي.
3. أضف الطريقة أو الأداة إن أفادت.
4. اختم بنتيجة أو رقم من تطبيقاتك.

الإجابة النموذجية

السطر الضعيف	الصياغة المقترحة
Responsible for risk assessment.	Assessed a vendor remote-access risk for a fictional 200-staff company; rated it High (16) and proposed 5 actions with owners and dates.
Helped with access review.	Tested a quarterly access review against 6 evidence items; rated it partially implemented and wrote a finding with a 4-step corrective plan.
Familiar with NCA ECC.	Mapped ECC-2:2024 controls 2-2-3-2 and 2-2-3-5 to evidence requests and test steps for a training case.

متى تكون إجابتك مقبولة وإن اختلفت عن النموذج

• أي صياغة تتبع المعادلة وتستخدم أرقاماً حقيقية من تطبيقاتك. وإن كانت من مشروع تدريبي فلا تخفِ ذلك.

أخطاء شائعة

• المبالغة: «Led the GRC program».
• الاكتفاء بالمسؤوليات بلا نتيجة.
• ذكر أداة أو إطار لم تعمل به فعلاً.

اختبار الوحدة 07: السيرة الذاتية

1. أي سطر أقوى؟

الإجابة: (ب) Assessed a vendor access risk; rated it High (16) and proposed 5 actions.

• لماذا: فعل، وما فعلته، ونتيجة برقم.
• لماذا ليس (أ): مسؤولية بلا إنجاز.

2. عن أنظمة الفرز ATS:

الإجابة: (ب) الأنظمة تختلف؛ البسيط أضمن

• لماذا لا قاعدة واحدة لكل الأنظمة.

3. كتابة «Led the GRC program» عن مشروع تدريبي:

الإجابة: (ب) مبالغة تنكشف في المقابلة

• لماذا: صف العمل بحجمه.

التمرين 16: عنوانك المهني وافتتاح نبذتك

الإجابة في العرض: الشريحة 206.

طريقة الحل

1. العنوان: الوظيفة المستهدفة | مجالان أو ثلاثة بكلمات يبحث بها مسؤول التوظيف | دليل: شهادة أو مشروع.
2. افتتاح النبذة جملتان: من أنت وماذا تفعل، ثم أقوى دليل من مشاريعك.

الإجابة النموذجية

العنوان المهني	Entry-Level GRC Analyst | Risk Assessment · Control Testing · NCA ECC | ISC2 CC
افتتاح النبذة	Entry-level GRC analyst who turns requirements into clear, testable controls. In a training case for a 200-staff company, I rated a vendor access risk, tested an access review, and wrote a finding with a corrective plan.

أخطاء شائعة

- عنوان بلا وظيفة مستهدفة: «Student at…» أو «Looking for opportunities».
- صفات عامة بلا دليل: «Hard worker».
- ذكر شهادة لم تحصل عليها بعد بصيغة توحي بأنك حصلت عليها.

اختبار الوحدة 08: لينكدإن والفرص

1. العنوان المهني الجيد:
الإجابة: (ب) الوظيفة المستهدفة | مجالان أو ثلاثة | دليل
- لماذا: بكلمات يبحث بها مسؤول التوظيف.

2. خيار Open to Work لمسؤولي التوظيف فقط:
الإجابة: (ب) تحاول لينكدإن إخفاءه ولا تضمن ذلك
- لماذا: كما في صفحة مساعدة لينكدإن.

3. عند البحث عن وظائف:
الإجابة: (ب) استخدم عدة مسميات وتنبيهاً لكل منها
- لماذا: المسمى نفسه يتغير بين الجهات.

التمرين 17: قصتك بطريقة STAR

الإجابة في العرض: الشريحة 213.

طريقة الحل

1. الموقف والمهمة باختصار: جملة لكل منهما.
2. الإجراء هو الجزء الأطول، بصيغة «أنا»: ماذا فعلت خطوة خطوة، ولماذا.
3. النتيجة: رقم، أو قرار، أو مخرج، وما تعلمته.
4. إن كانت التجربة تدريبية فقل ذلك في الموقف.

الإجابة النموذجية

السؤال: «حدثنا عن مرة اكتشفت فيها مشكلة في ضابط ولم يكن الدليل واضحاً.»

	الجزء	الإجابة
S	الموقف	في مشروع تدريبي لشركة افتراضية، كان المطلوب تقييم مراجعة الصلاحيات الفصلية في نظام الرواتب.
T	المهمة	تحديد نتيجة التقييم من 6 أدلة متفاوتة.

	الجزء	الإجابة
A	ما فعلته أنا	ربطت كل دليل بما يثبته، فوجدت أن الربع الثاني لم يُنفذ وأن حسابين لمغادرين بقيا نشطين، ثم طلبت سجل الترحيل للتحقق من السبب بدل الاعتماد على البريد.
R	النتيجة	قيّمت الضابط «مطبقاً جزئياً» وكتبت ملاحظة بخطة تصحيح من 4 إجراءات، ونشرت المشروع في ملف أعمالي.

أخطاء شائعة

- استخدام «نحن» فلا يعرف المقابل ما فعلته أنت.
- إطالة الموقف وإهمال الإجراء.
- إنهاء القصة بلا نتيجة.
- تقديم المشروع التدريبي كأنه خبرة عمل في جهة حقيقية.

اختبار الوحدة 09: المقابلة والانطلاق

1. في قصة STAR، الجزء الأطول:

الإجابة: (ب) ما فعلته أنا

- لماذا: هو ما يقيّمه المقابل.

2. مالك نظام يرفض ضابطاً. أول خطوة:

الإجابة: (ب) فهم السبب: كلفة، أم تعطيل عمل، أم سوء فهم؟

- لماذا: ثم تشرح الخطر بلغة العمل وتقترح بديلاً.
- لماذا ليس (أ): التصعيد آخر خطوة، بعد البدائل والقبول الموثق.

3. عند الحديث عن مشروع تدريبي:

الإجابة: (ب) تقول إنه تدريبي، وتشرح ما فعلته فيه

- لماذا: الصدق يبني الثقة.

التقييم الختامي: النسخ الاحتياطي لنظام الموارد البشرية والرواتب

الحالة في العرض: الشريحة 215. هذه إجابة نموذجية ومعايير تصحيح؛ الصياغة قد تختلف، والمبرر هو ما يُقيَّم.

1. الخطر وتقييمه

الخطر: بسبب نسخ يومي لا يحقق حد فقد البيانات المقبول، وعدم اختبار الاستعادة، قد يتعذر استرجاع بيانات الرواتب كاملة وفي الوقت المطلوب بعد عطل أو حادثة، مما يؤخر صرف رواتب نحو 200 موظف أو يصرفها خاطئة.

الاحتمال 3 (غير مرجح): لم يقع فقد بيانات في الفترة، لكن الاستعادة لم تُجرَّب قط وفشل التصدير مرتين دون متابعة. الأثر 4 (عالٍ): يمس رواتب كل الموظفين وثقتهم. المستوى 3 × 4 = 12 · متوسط: خطة معالجة أو قبول موثق من الرئيس التنفيذي.

2. الضوابط

الضابط	المالك
اختبار استعادة ربع سنوي من نسخة المزود ومن التصدير، بمحضر ونتيجة	م. سلمان
مواءمة RPO مع الواقع: تصدير كل 4 ساعات، أو بند في العقد بنسخ أكثر تكراراً، أو تعديل RPO بقرار موثق	أ. منى، وأ. فهد للعقد
تنبيه آلي عند فشل التصدير، وتذكرة متابعة لكل فشل	م. سلمان

3. تقييم الأدلة

الدليل	ماذا يثبت	ماذا لا يثبت	نوع الفجوة
د1	المتطلب الداخلي: RTO يوم عمل وRPO 4 ساعات.	أن النسخ يحققهما.	المعيار
د2	تصميم النسخ عند المزود: يومي، واستعادة خلال يومي عمل.	أن الاستعادة جُربت. ويتعارض مع RTO وRPO.	فجوة تصميم
د3	أن التصدير يعمل غالباً، وفشل مرتين.	أن الفشلين عولجا.	فجوة تشغيل
د4	غياب اختبار الاستعادة طوال الفترة.	شيئاً عن صلاحية النسخ.	فجوة تنفيذ لمتطلب 2-3-9-3

4. الملاحظة

العنوان	النسخ الاحتياطي لنظام الرواتب لا يحقق متطلبات الاستمرارية، والاستعادة لم تُختبر
الوضع القائم	نسخة المزود يومية والاستعادة خلال يومي عمل، والمطلوب RPO أربع ساعات وRTO يوم عمل. لم يُجرَ أي اختبار استعادة بين يناير ويونيو 2026، وفشل التصدير الأسبوعي مرتين دون متابعة.
المعيار	ECC 2-9-3-2 و2-9-3-3 كما تبنّتها رُفاد، وتحليل أثر الأعمال المعتمد في فبراير 2026.
السبب	افتراض أن النسخ مسؤولية المزود وحده، وغياب إجراء لاختبار الاستعادة ومتابعة الفشل. تحققنا من ذلك بالعقد وبريد تقنية المعلومات.
الأثر	قد يتأخر صرف الرواتب أو يخطئ بعد عطل، وقد نفقد يوم عمل من التعديلات.
التوصية	اختبار استعادة عاجل، ثم مواءمة النسخ مع RPO، وإجراء لاختبار دوري ومتابعة الفشل. التفاصيل في خطة التصحيح.

خطة التصحيح

الإجراء	النوع	المالك	الموعد	دليل الإغلاق
اختبار استعادة عاجل من نسخة المزود ومن التصدير	معالجة الحالة	م. سلمان	10 أيام عمل	محضر الاختبار بالوقت المستغرق والنتيجة
متابعة سبب فشلي التصدير وإصلاحه	معالجة الحالة	م. سلمان	5 أيام عمل	تذكرة المتابعة، وتقرير تشغيل ناجح

الإجراء	النوع	المالك	الموعد	دليل الإغلاق
مواءمة النسخ مع RPO: تصدير كل 4 ساعات أو تعديل العقد، أو قرار موثق بتعديل RPO	منع التكرار	أ. منى	60 يوماً	الإعداد الجديد أو ملحق العقد أو القرار
إجراء معتمد لاختبار الاستعادة كل ربع سنة، وتنبيه آلي عند فشل التصدير	منع التكرار	م. سلمان	30 يوماً	الإجراء المعتمد، وإعداد التنبيه

معايير التصحيح

- الخطر بسبب وحدث وأثر، والدرجتان مبررتان من المقياس.
- ضابطان على الأقل يعالجان السبب، ولكل منهما مالك واحد بالوظيفة.
- لكل دليل: ما يثبته وما لا يثبته، ونوع الفجوة.
- الملاحظة بعناصرها الخمسة وأرقامها، والخطة فيها إجراء فوري وإجراء يمنع التكرار.

متى تكون إجابتك مقبولة وإن اختلفت

- الاحتمال 2 أو 4 مقبول بمبرر من المقياس. المهم أن يتبع القرار قاعدة القبول للمستوى الناتج.
- تعديل RPO بقرار موثق من صاحب الصلاحية حل مقبول، إن بُني على تحليل أثر جديد لا على صعوبة التنفيذ.
- اعتبار د2 «فجوة تصميم في العقد» أو «في الضابط» كلاهما صحيح: النسخ اليومي لا يحقق 4 ساعات مهما نُفذ.

أخطاء شائعة

- «المزود مسؤول» دون النظر في العقد: البيانات وقرار الاستمرارية مسؤولية رُفاد.
- الحكم بأن النسخ سليمة لأن التصدير نجح غالباً: النجاح ليس استعادة.
- خطة بلا اختبار استعادة.